

YOUR DIGITAL GHOST

*What Attackers Already Know
Before They Strike*

Version: 1.3

Author: Sylvain Martinez

Classification: PUBLIC

{elysiumsecurity}
cyber protection & response

What attackers can discover about your organisation before an attack begins - and how to reduce what they can use against you.

1. CONTEXT:

THE INVISIBLE RECONNAISSANCE PHASE

2. ATTACK:

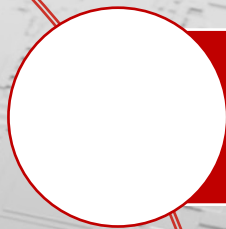
THE ATTACKER'S TOOLKIT – WHAT THEY FIND

3. DEFENCE:

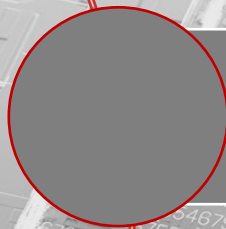
REDUCING YOUR DIGITAL SHADOW

4. CONCLUSION:

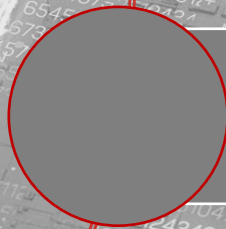
3 TAKEAWAYS & ACTIONS YOU CAN TAKE NOW



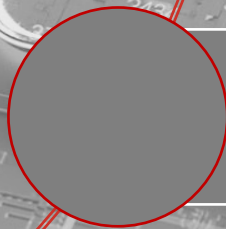
CONTEXT



ATTACK



DEFENCE



CONCLUSION

"Open Source Intelligence (OSINT) is the collection and analysis of information from publicly available sources. No hacking. No illegal access."



INTERNET & WEB

Websites, search engines, news archives, DNS records, SSL certificates, cached pages, archived content



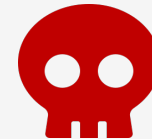
PEOPLE & SOCIAL

LinkedIn, Facebook, X, Instagram, job postings, company directories, conference speaker lists



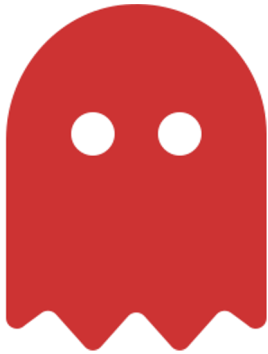
INFRASTRUCTURE

Shodan, Censys, WHOIS, BGP routing tables, cloud metadata, exposed API endpoints



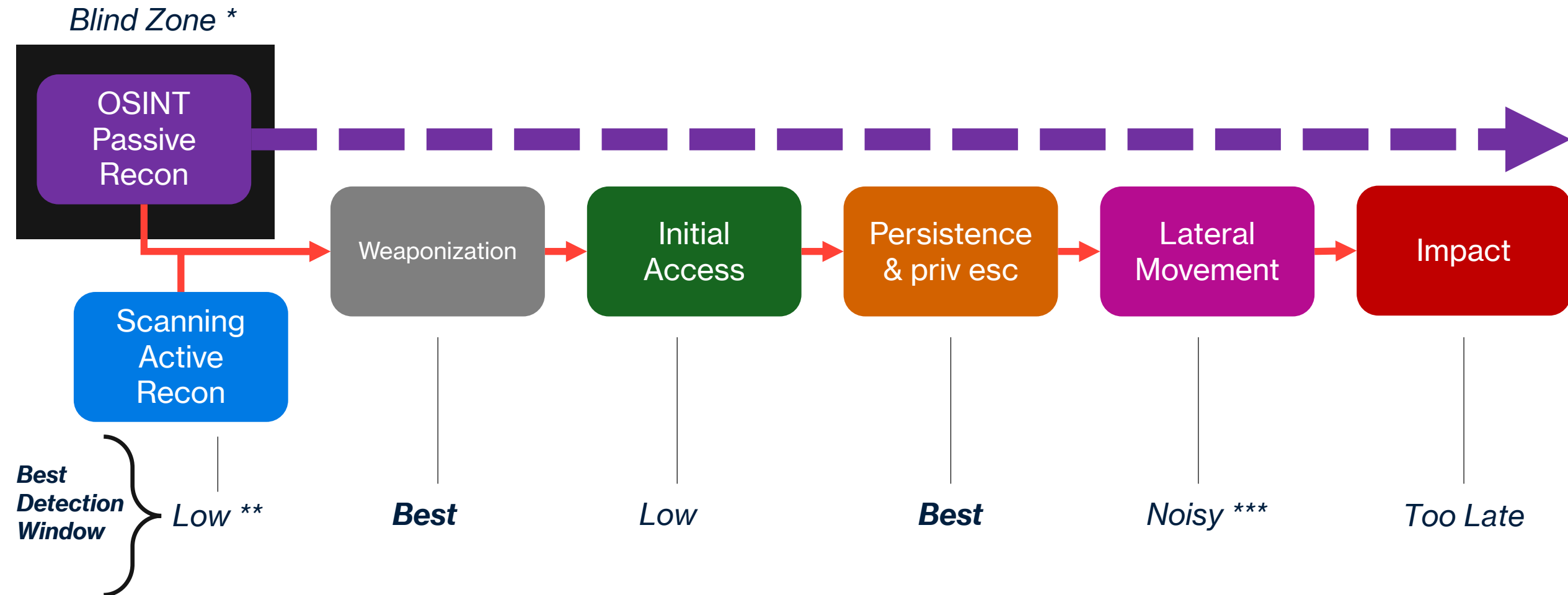
DARK WEB

Breach databases, credential markets, threat actor forums, IAB listings, data leak sites



OSINT often happens before dwell time begins - and usually leaves no trace on your systems.

-  No logs generated on your infrastructure
-  No alerts triggered in your SIEM
-  No firewall or IDS entries
-  Usually invisible to defenders



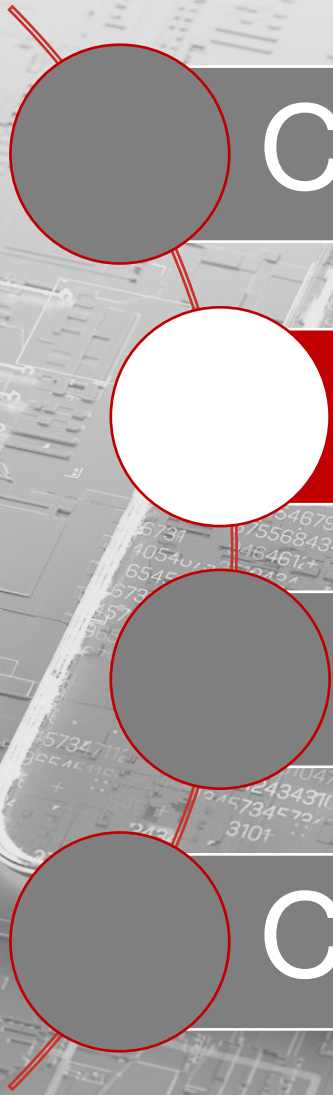
* OSINT used in active recon mode generates some noise

** Active Scanning generates noise but is often ignored

*** Lateral Movement can look legitimate

- 1. Reduced cost and skills of entry – just a prompt
- 2. Reduced time of execution:

ATTACK CHAIN	PRE-AI	POST-AI
Passive Recon	Weeks to Months	Hours
Active Recon	Days to Weeks	Minutes to Hours
Weaponization	Days	Minutes via GenAI
Initial Access ->Lateral move	Hours to Minutes	Will soon be seconds
TOTAL:	Weeks to Months	Days to Hours (minutes?)



CONTEXT

ATTACK

DEFENCE

CONCLUSION

**SERVICE & LOCAL TOOLS**

- Exposed ports & services
- Software versions + known CVEs
- Default creds detected
- Cloud misconfigurations
- Unexpected devices online

**DNS & WHOIS**

- Domain registrant details
- Mail server (MX) config
- Related & historical domains
- Zone transfer misconfigs
- Full DNS history over time

**CERT TRANSPARENCY**

- ALL subdomains in SSL certs
- Internal app names revealed
- Staging & dev environments
- Acquisition target domains
- Cert expiry = attack window

 *Live demo: shodan.io * crt.sh * securitytrails.com * viewdns.info * recon-ng * theHarvester * spiderfoot all free*

Live Demo - Screenshots

```
$ theHarvester bbc.co.uk -b duckduckgo
read proxies.yaml from /etc/theHarvester/proxies.yaml

*****
theHarvester
*****

theHarvester 4.10.1
  Coded by Christian Martorella
  Edge-Security Research
  cmartorella@edge-security.com

*****

[*] Target: bbc.co.uk

[*] Searching Duckduckgo.

[*] No IPs found.

[*] No emails found.

[*] No people found.

[*] Hosts found: 10

2Fid.bbc.co.uk
2Fnews.bbc.co.uk
1Fsupport.bbc.co.uk
1Fbackstage.bbc.co.uk
1d.bbc.co.uk
backstage.bbc.co.uk
creativearchive.bbc.co
1d.bbc.co.uk
news.bbc.co.uk
support.bbc.co.uk
```

The image shows the Spiderfoot web interface. At the top, the 'bbc' domain is listed with a status of 'RUNNING'. Below this, a navigation bar contains buttons for 'Summary', 'Correlations', 'Browse', 'Graph' (which is selected), 'Scan Settings', and 'Log'. The main area displays a network graph. A central red dot represents the target domain 'bbc'. Numerous lines radiate from this central point to various black dots, which represent discovered subdomains or related IP addresses. The graph illustrates the network structure of the 'bbc' domain as known by Spiderfoot.

[illegible]

Scans Settings Light Mode

relations Browse Graph Scan Settings Log

Search...

	Unique Data Elements	Total Data Elements	Last Data Element
	3	3	2026-04-29 18:27:05
	1	1	2026-04-29 18:25:49
	1	1	2026-04-29 18:27:11
	7	7	2026-04-29 18:27:11
	1	1	2026-04-29 18:25:49
	1	1	2026-04-29 18:27:09
	1	1	2026-04-29 18:27:09
	4	5	2026-04-29 18:26:47
	4	4	2026-04-29 18:27:05
	11	11	2026-04-29 18:27:05
	1	1	2026-04-29 18:26:48
	3	3	2026-04-29 18:27:05
	2	2	2026-04-29 18:27:17
	41	42	2026-04-29 18:27:05
	1	1	2026-04-29 18:27:11
	21	21	2026-04-29 18:26:46

WHAT ATTACKERS EXTRACT

- Full org chart — names, roles, reporting lines
- Email format confirmed: first.last@company.mu
- IT and security team identified by name
- Who likely holds privileged access
- Personal social media profiles cross-linked
- Physical office layout (Google Maps / StreetView)
- Employee travel patterns (frequent airports, hotels)

"Your Security Engineer job posting just told attackers you use Cisco ASA, Splunk, CrowdStrike, AWS."

THE ATTACKER'S TOOLS

- LinkedIn + Sales Navigator (org reconstruction)
- theHarvester · Hunter.io (email harvesting)
- FOCA · Metagoofil (document metadata)
- Google Dork: filetype:pdf site:company.mu
- Maltego (relationship mapping)

30 minutes on LinkedIn → reconstructed org chart → precise spear-phishing targets selected

17B+

RECORDS LEAKED IN THE LAST 12 YEARS

Source: HaveIBeenPwned

\$5–\$20

Valid email:password pairs from past breaches

\$50–\$500

Pre-sold VPN / RDP access to corporate networks

\$20–\$80

Employee PII — home addresses, phones, personal emails

\$200–\$10k

Initial Access Broker packages (ready-to-use footholds)

(*) 2024 pricing

⚠ Free check: haveibeenpwned.com - see which of your staff are exposed right now

Public documents often contain hidden metadata that exposes internal information.



Author username

Windows login name reveals naming convention



Software version

Office 2016 SP2? Now they know your patch level



Internal paths

UNC paths: \\FS01-HQ\\finance\\... reveals servers



Printer names

Printer queue names expose site topology



Email signatures

Old PDFs contain current employee email formats



GPS coordinates

Phone-created documents reveal physical locations

Free tools that extract all of this: FOCA · Metagoofil · ExifTool – minutes to scan, high-value results

Before a single packet hits your network — the attacker already has:



ORGANISATION

- ✓ Network IP ranges & ASN
- ✓ Email server type & MX config
- ✓ Internet-facing services
- ✓ Cloud provider & CDN vendor
- ✓ Full technology stack



PEOPLE

- ✓ Key personnel & org chart
- ✓ Confirmed email format
- ✓ IT and security team names
- ✓ Personal social profiles
- ✓ Who holds admin credentials



VULNERABILITIES

- ✓ Unpatched exposed systems
- ✓ Leaked valid credentials
- ✓ Exposed staging/dev apps
- ✓ SSL cert expiry windows
- ✓ Shadow IT & forgotten assets

The breach that follows is rarely random. It is informed, prepared, and targeted.

1

**DISCOVER
FOOTPRINT**

Domains
People
Exposures

KEY POINT

2

**SELECT
TARGET**

Choose the
best user
or asset

3

**PREPARE
PRETEXT**

Spoof brand
Write lure
Stage access

4

**INITIAL
ACCESS**

Phish, reuse
creds, or
exploit

5

**MOVE
FASTER**

Less noise
Fewer misses
Higher odds

Better OSINT means faster, quieter, more precise compromise.



CONTEXT

ATTACK

DEFENCE

CONCLUSION

Run the same discovery process on yourself that an attacker would:

1

DISCOVER



Use Shodan, crt.sh, HaveIBeenPwned, SecurityTrails, and Google Dorks.

Look at your organisation exactly as an attacker would — no assumptions, no shortcuts, no 'but we have a firewall'.

2

ANALYZE



Prioritise findings by risk.

Exposed RDP = critical.
Old PDF metadata = low.

Build a risk-ranked list of your digital exposures with clear ownership for each item.

3

REMEDiate



Act on the findings.

Close exposed ports, strip document metadata, force password resets on breached accounts, remove unnecessary public information.

Free tools: shodan.io * haveibeenpwned.com * crt.sh * [spiderfoot](https://spiderfoot.net) * [Google Dorks](https://www.google.com/search?q=Google+Dorks)

Don't check manually every day — set up automated alerts:



HaveIBeenPwned Domain Alerts

Register your domain at haveibeenpwned.com/domain — 5 minutes to configure, free. Email alert whenever any @yourcompany address appears in a new breach.



Certificate Transparency Watch

CertStream and SSLMate alert when new SSL certs are issued for domains resembling yours. Catches attacker phishing domains before launch. Add multiple remainders for expiry!



Shodan Monitor (free tier?)

Register your IP ranges — alert when new services or ports appear on your perimeter. Catches developer accidental exposures instantly.



Brand & Typosquat Monitoring

Tools like DNSTwist and URLCrazy detect domains like mydomain.com being registered before the phishing campaign launches.

Total setup time for all four: under 30 minutes. Total cost: low or zero.

Stop leaking internal intelligence through every PDF you publish:

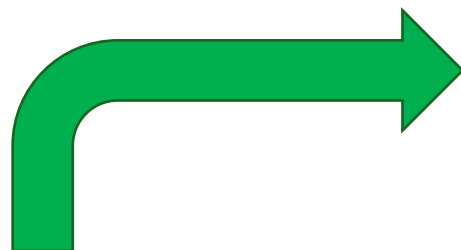


Example command to display metadata from a file:

```
exiftool -a -u -g1 file.pdf
```

Example command to strip metadata from PDFs in a folder:

```
exiftool -all= file.pdf
```



```
L% exiftool -a -u -g1 TALK2_MariaDB_oceandba.pdf
---- ExifTool ----
ExifTool Version Number      : 13.55
---- System ----
File Name                    : TALK2_MariaDB_oceandba.pdf
Directory                    : .
File Size                    : 1468 kB
File Modification Date/Time   : 2026:04:07 17:51:15+04:00
File Access Date/Time        : 2026:04:30 19:17:44+04:00
File Inode Change Date/Time   : 2026:04:30 19:17:42+04:00
File Permissions              : -rw-r--r--
---- File ----
File Type                    : PDF
File Type Extension          : pdf
MIME Type                    : application/pdf
---- PDF ----
PDF Version                  : 1.7
Linearized                   : No
Page Count                   : 58
Page Mode                    : UseOutlines
Producer                     : pdfTeX-1.40.29
Author                       : Joffrey MICHAIE
Title                        : MariaDB Database: A Dive Into Security - Hardening Your Database Infrastructure
Subject                       :
Creator                      : LaTeX with Beamer class
Create Date                  : 2026:04:07 15:44:46+04:00
Modify Date                  : 2026:04:07 15:44:46+04:00
Trapped                      : False
PTeX Fullbanner              : This is pdfTeX, Version 3.141592653-2.6-1.40.29 (TeX Live 2026/Homebrew) kpathsea version 6.4.2
```

```
L% exiftool -a -u -g1 TALK2_MariaDB_oceandba.pdf
---- ExifTool ----
ExifTool Version Number      : 13.55
---- System ----
File Name                    : TALK2_MariaDB_oceandba.pdf
Directory                    : .
File Size                    : 1469 kB
File Modification Date/Time   : 2026:04:30 19:18:54+04:00
File Access Date/Time        : 2026:04:30 19:18:56+04:00
File Inode Change Date/Time   : 2026:04:30 19:18:54+04:00
File Permissions              : -rw-r--r--
---- File ----
File Type                    : PDF
File Type Extension          : pdf
MIME Type                    : application/pdf
---- PDF ----
PDF Version                  : 1.7
Linearized                   : No
Page Count                   : 58
Page Mode                    : UseOutlines
```

Same candidate quality — far less attacker intelligence:

✗ WHAT NOT TO WRITE

Splunk 9.x enterprise deployment experience

AWS GuardDuty, CloudTrail, Security Hub

Cisco ASA 5500-X firewall administration

CrowdStrike Falcon tuning, Carbon Black

Palo Alto PAN-OS 11.x config, GlobalProtect

Active Directory 2019, Azure AD Connect v2

✓ WHAT TO WRITE INSTEAD

Enterprise SIEM platform experience

Cloud security monitoring tools

Enterprise firewall platform experience

EDR platform deployment and tuning

NGFW and remote access VPN experience

Enterprise directory services experience

Qualified candidates still understand the role. Attackers lose a clean map of your stack.

01**Social Media Policy**

Explicitly ban photos of: ID badges, building access systems, computer screens, office interiors, floor plans. Employees don't know these are intel.

02**OSINT Awareness Exercise**

Ask employees to spend 15 minutes Googling themselves before security training. Personal discovery is often the most effective awareness moment.

03**Third-Party Exposure Review**

Vendors, partners, consultants have OSINT-visible connections to you. Their exposure becomes yours. Include them in quarterly reviews.

04**Executive Privacy**

CEO, CFO, board members are priority targets. Home addresses, family names, children's schools - all need privacy hardening, not just the corporate side.



CONTEXT

ATTACK

DEFENCE

CONCLUSION

CONCLUSION

3 Take-aways

You do not need to eliminate your public footprint. You need to reduce what attackers can reliably use.

VISIBILITY

Attackers rarely start blind. They start with your public exhaust: domains, people, documents, and exposures.

HYGIENE

Small leaks compound. A PDF, a job ad, a LinkedIn profile, and an exposed service can become one attack path.

MONITORING

If you can see new exposure early, you can often close it before it is weaponised.

OSINT is not a niche issue. It is the pre-attack layer of modern intrusion.

CONCLUSION Your Digital Ghost – Action Checklist



TODAY

Search your company on shodan.io - what is exposed?
Check haveibeenpwned.com for your corporate domain/main email accounts
Google: site:yourcompany.mu filetype:pdf



THIS WEEK

Run crt.sh for your domain - list every subdomain in certificate history
Review the top 10 LinkedIn profiles in your IT and security team
Run ExifTool on 20 public PDFs from your website



THIS MONTH

Make metadata stripping a publish gate
Rewrite job postings to abstract specific products and versions
Set up HaveIBeenPwned, Shodan Monitor, and certificate transparency alerts

"See your organisation the way an attacker does."

THANK YOU!

Any Questions?



ABOUT ELYSIUMSECURITY LTD.

ELYSIUMSECURITY PROVIDES A PORTFOLIO OF **STRATEGIC** AND **TACTICAL SERVICES** TO HELP COMPANIES **PROTECT** AND **RESPOND** AGAINST **CYBER SECURITY THREATS**. WE DIFFERENTIATE OURSELVES BY OFFERING **DISCREET, TAILORED** AND **SPECIALIZED** ENGAGEMENTS.

ELYSIUMSECURITY OPERATES IN **MAURITIUS** AND IN **EUROPE**, A **BOUTIQUE STYLE** APPROACH MEANS WE CAN **EASILY ADAPT** TO YOUR BUSINESS OPERATIONAL MODEL AND REQUIREMENTS TO PROVIDE A **PERSONALIZED SERVICE** THAT FITS YOUR WORKING ENVIRONMENT.

ELYSIUMSECURITY PROVIDES **HIGH LEVEL EXPERTISE** GATHERED THROUGH YEARS OF **BEST PRACTICES EXPERIENCE** IN LARGE INTERNATIONAL COMPANIES ALLOWING US TO PROVIDE ADVICE BEST SUITED TO YOUR **BUSINESS OPERATIONAL MODEL** AND **PRIORITIES**.

ELYSIUMSECURITY PROVIDES **PRACTICAL EXPERTISE** TO **IDENTIFY VULNERABILITIES**, ASSESS THEIR **RISKS** AND **IMPACT**, **REMEDiate** THOSE RISKS, **PREPARE** AND **RESPOND** TO INCIDENTS AS WELL AS RAISE **SECURITY AWARENESS** THROUGH AN ORGANIZATION.

